

Compte rendu complet des travaux pratiques de test intrusion

Préparation de Kali Linux et phase de reconnaissance

BTS SIO deuxième année option SISR

Réalisé par Fahad

Année scolaire 2026 2027

Périmètre autorisé

Machines virtuelles du laboratoire et serveur pédagogique btssiogap.com

Sommaire

- 1 Présentation et objectifs
- 2 TP 1 1 Téléchargement de Kali Linux et VirtualBox
- 3 TP 1 3 Installation des Additions invité
- 4 TP 2 1 Méthodologie du test intrusion
- 5 TP 2 2 Préparation des machines et du réseau
- 6 TP 2 3 Phase de reconnaissance
- 7 Exercice 7 Scan du serveur web autorisé
- 8 Bilan et conclusion

Présentation et objectifs

Ces travaux pratiques ont pour objectif de préparer un laboratoire de test d'intrusion, de comprendre la méthodologie d'un audit de sécurité et de réaliser une première phase de reconnaissance. Le laboratoire comprend une machine Kali Linux utilisée comme poste de test et une machine Windows 7 utilisée comme cible locale. La partie finale porte sur un serveur web pédagogique explicitement autorisé par l'enseignant.

Le résultat principal est la mise en place d'un environnement fonctionnel : les deux machines communiquent dans les deux sens, la documentation est organisée dans CherryTree et SpiderFoot a permis de collecter des informations publiques sur le domaine autorisé.

Élément	Valeur
Machine de test	Kali Linux 64 bits
Machine cible locale	Windows 7 SP1
Hyperviseur	Oracle VM VirtualBox
Réseau du laboratoire	172.30.0.0/16
Serveur web autorisé	btssiogap.com
Outils principaux	Terminal, CherryTree et SpiderFoot

TP 1 1 Téléchargement de Kali Linux et VirtualBox

Objectif

L'objectif est de disposer d'un système Kali Linux isolé dans une machine virtuelle. Kali regroupe les outils nécessaires aux tests de sécurité, tandis que VirtualBox permet d'exécuter plusieurs systèmes sans modifier directement le poste physique.

Étapes réalisées

- Téléchargement de l'image ISO officielle de Kali Linux en version 64 bits.
- Téléchargement puis installation de VirtualBox sur le poste hôte.
- Création d'une nouvelle machine virtuelle de type Linux 64 bits.
- Attribution de 2 Go de mémoire vive et création d'un disque virtuel de 25 Go.
- Démarrage sur l'image ISO et installation de Kali Linux.
- Création du compte utilisateur fahad puis vérification du démarrage du système.

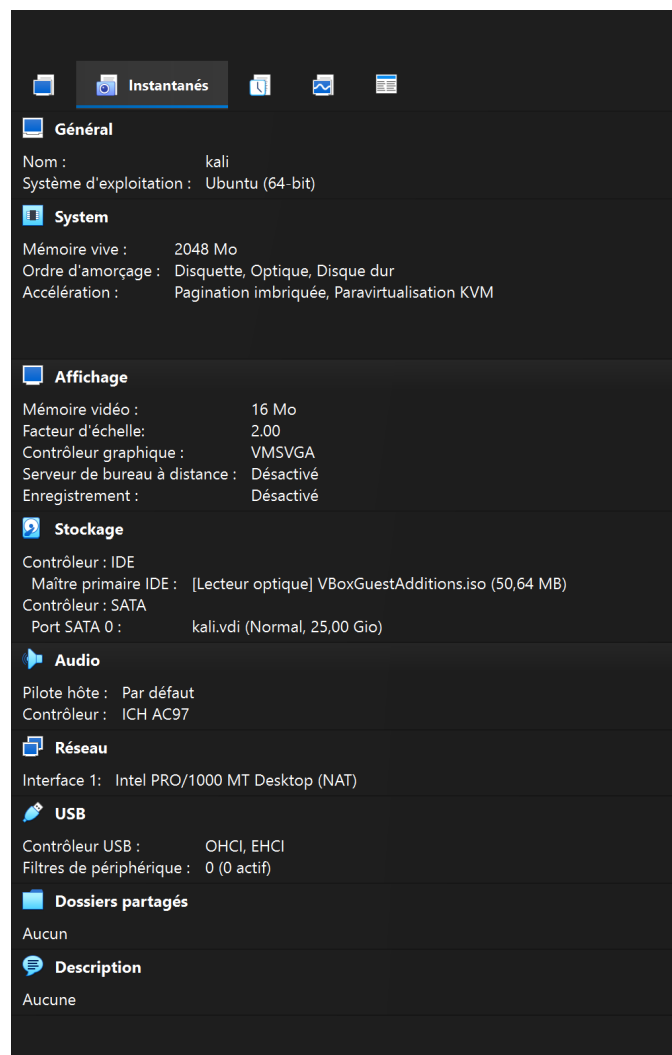


Figure 1 Caractéristiques de la machine virtuelle Kali Linux

La capture confirme que la machine virtuelle est configurée avec 2 048 Mo de mémoire vive, un processeur virtuel et un disque de 25 Go. Cette configuration est suffisante pour les outils utilisés dans ce TP.

Mise à jour du système

Après l'installation, les listes de paquets et le système ont été mis à jour avec les commandes suivantes :

```
sudo apt update
sudo apt dist-upgrade
```

Cette opération permet d'obtenir les dernières corrections et versions disponibles dans les dépôts configurés.

TP 1 3 Installation des Additions invité

Rôle des Additions invité

Les Additions invité ajoutent des pilotes et des fonctions d'intégration entre VirtualBox et Kali Linux. Elles améliorent notamment l'affichage, le redimensionnement de la fenêtre, la souris et, lorsque VirtualBox est correctement configuré, le presse-papiers partagé.

Procédure suivie

- Dans la fenêtre de la machine virtuelle, ouverture du menu Périphériques.
- Sélection de Insérer l'image CD des Additions invité.
- Ouverture du lecteur virtuel apparu dans Kali Linux.
- Ouverture d'un terminal dans le dossier du lecteur.
- Passage en administrateur puis lancement du programme d'installation.
- Redémarrage de la machine virtuelle pour appliquer les modifications.

```
sudo su
sh VBoxLinuxAdditions.run
reboot
```

Après le redémarrage, le système est prêt pour la suite du laboratoire. Le copier-coller entre l'hôte et la machine virtuelle dépend également du réglage Périphériques, Presse-papiers partagé, Bidirectionnel.

Configuration de la carte réseau VirtualBox

La carte réseau de la machine Kali a été placée en mode accès par pont. Dans ce mode, la machine virtuelle apparaît sur le même réseau que les autres postes du laboratoire.

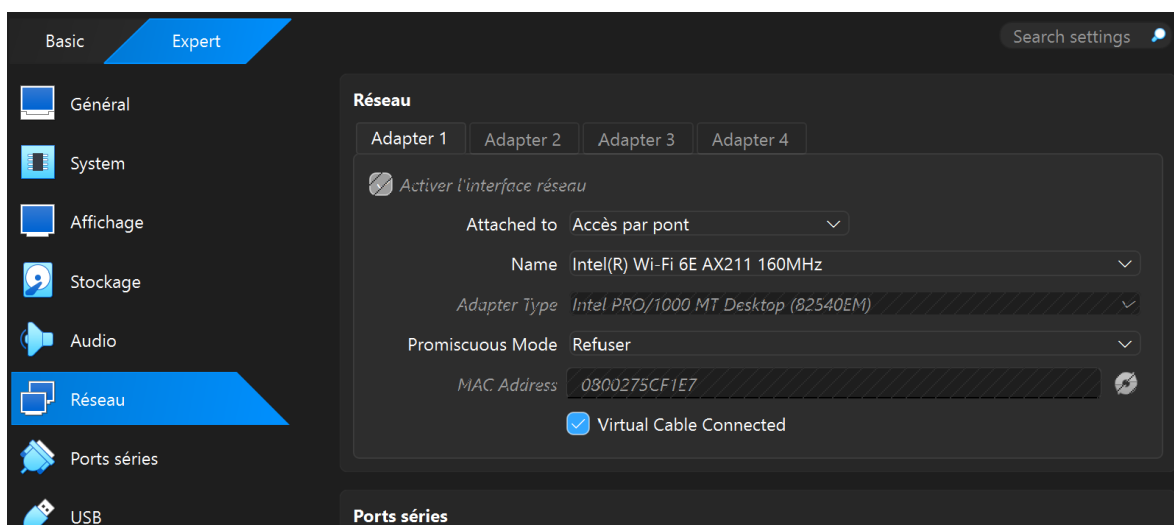


Figure 2 Carte réseau VirtualBox configurée en accès par pont

TP 2 1 Méthodologie du test intrusion

Un test d'intrusion doit suivre une méthode et un périmètre précis. L'autorisation du propriétaire est indispensable avant toute analyse active. Les principales méthodes de référence étudiées sont OWASP, PTES, OSSTMM et NIST.

Référence	Rôle
OWASP	Bonnes pratiques et méthodes de sécurité des applications web.
PTES	Standard structurant les différentes phases d'un test d'intrusion.
OSSTMM	Méthode de test de sécurité opérationnelle mesurable.
NIST	Cadres et recommandations de cybersécurité et de gestion des risques.

Méthode retenue pour les TP

Étape	But
Négociation	Définir l'autorisation, les cibles, les limites et les règles d'engagement.
Reconnaissance	Collecter des informations sur la cible de manière passive ou active.
Scanning	Identifier les hôtes, ports, services et éléments techniques exposés.
Gain d'accès	Tester une exploitation uniquement si elle est autorisée.
Maintien d'accès	Évaluer la possibilité de conserver un accès dans le périmètre prévu.
Nettoyage	Retirer les fichiers et modifications créés pendant le test.
Rapport	Présenter les actions, preuves, résultats, risques et recommandations.

Dans les travaux réalisés ici, nous nous sommes arrêtés à la reconnaissance et au scan autorisé. Aucune exploitation ni tentative d'accès à la base de données n'a été réalisée.

TP 2 2 Préparation des machines et du réseau

Architecture du laboratoire

Machine	Adresse IPv4	Masque	Passerelle
Kali Linux	172.30.13.102	255.255.0.0	172.30.255.254
Windows 7	172.30.13.103	255.255.0.0	172.30.255.254

Les deux machines appartiennent au réseau 172.30.0.0/16 et utilisent la même passerelle. Elles ont été configurées en accès par pont afin de communiquer sur le réseau du laboratoire.

Configuration de Kali Linux

Dans les paramètres IPv4 de la connexion filaire, la méthode manuelle a été sélectionnée. L'adresse 172.30.13.102, le masque 255.255.0.0 et la passerelle 172.30.255.254 ont été saisis.

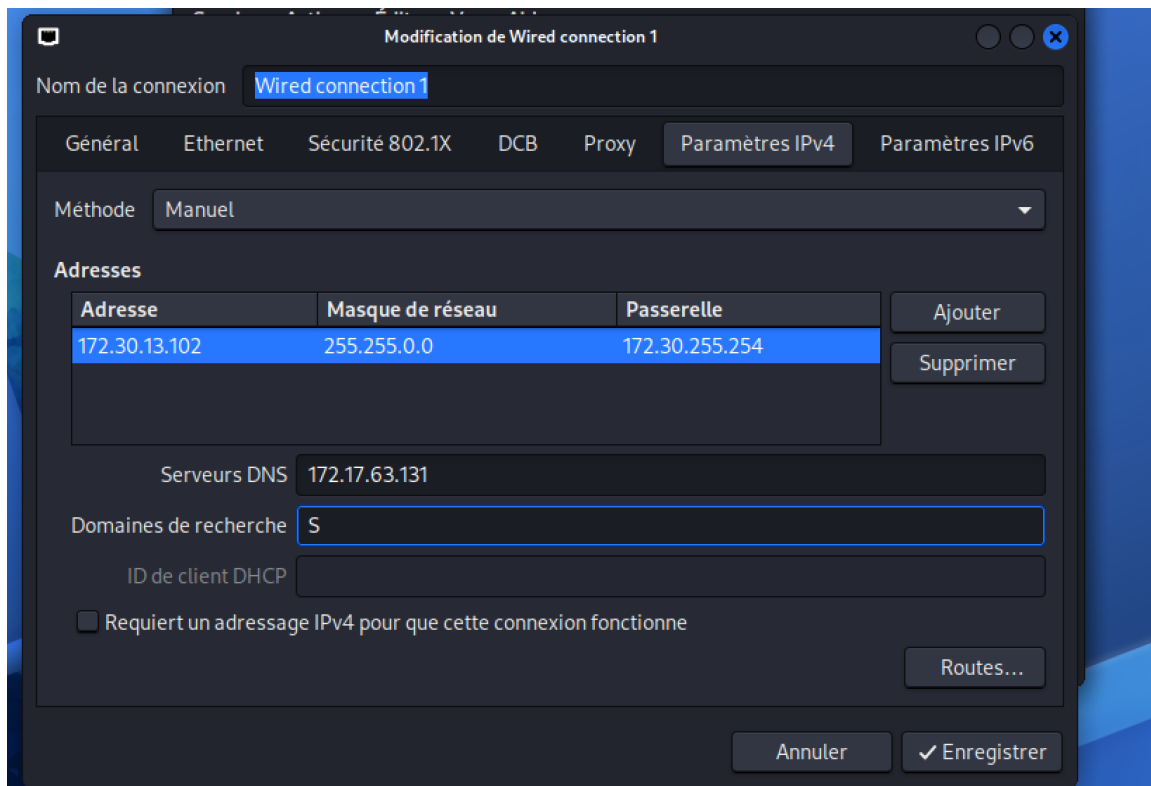


Figure 3 Paramètres IPv4 manuels de Kali Linux

La commande `ip a` a ensuite permis de vérifier l'adresse appliquée sur l'interface `eth0`.

`ip a`

```
fahad@fahad: ~  
Session Actions Éditer Vue Aide  
(fahad@fahad)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def  
ault qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g  
roup default qlen 1000  
    link/ether 08:00:27:5c:f1:e7 brd ff:ff:ff:ff:ff:ff  
    inet 172.30.13.102/16 brd 172.30.255.255 scope global noprefixroute eth0  
        valid_lft forever preferred_lft forever  
    inet6 fd17:625c:f037:2:6391:3936:1cdf:af5f/64 scope global temporary dyna  
mic  
        valid_lft 86381sec preferred_lft 14381sec  
    inet6 fd17:625c:f037:2:5051:a9d6:21aa:c13a/64 scope global dynamic mngtmp  
addr noprefixroute  
        valid_lft 86381sec preferred_lft 14381sec  
    inet6 fe80::1420:b082:e8fb:5d7/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(fahad@fahad)-[~]  
$
```

Figure 4 Vérification de l'adresse IPv4 de Kali Linux

Configuration et test de Windows 7

Windows 7 a reçu l'adresse 172.30.13.103/16. La commande ipconfig a permis de contrôler l'adresse, le masque et la passerelle configurés.

```
Carte Ethernet Connexion au réseau local :
    Suffixe DNS propre à la connexion. . . :
    Adresse IPv6 de liaison locale. . . . : fe80::dd46:1df8:772d:c1a%11
    Adresse IPv4. . . . . : 172.30.13.103
    Masque de sous-réseau. . . . . : 255.255.0.0
    Passerelle par défaut. . . . . : 172.30.255.254

Carte Tunnel isatap.{0C555987-1440-4EC1-ABF3-8E03679DE78D} :
    Statut du média. . . . . : Média déconnecté
```

Figure 5 Vérification de la configuration IPv4 de Windows 7

Tests de connectivité

Le premier test a été lancé depuis Windows 7 vers Kali Linux. Les quatre réponses ont été reçues avec 0 % de perte, ce qui confirme la communication vers 172.30.13.102.

```
ping 172.30.13.102
```

```
C:\Users\fahad>ping 172.30.13.103

Envoi d'une requête 'Ping' 172.30.13.103 avec 32 octets de données :
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128
Réponse de 172.30.13.103 : octets=32 temps<1ms TTL=128

Statistiques Ping pour 172.30.13.103:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
    Durée approximative des boucles en millisecondes :
        Minimum = 0ms, Maximum = 0ms, Moyenne = 0ms

C:\Users\fahad>S_
```

Figure 6 Ping réussi de Windows 7 vers Kali Linux

Le test inverse a d'abord échoué lorsque le pare-feu Windows bloquait les requêtes ICMP. Après la désactivation du pare-feu par l'enseignant dans le cadre du laboratoire, Kali Linux a reçu les quatre réponses avec 0 % de perte.

```
ping -c 4 172.30.13.103
```

```
(fahad@fahad)~  
$ ping -c 4 172.30.13.103  
PING 172.30.13.103 (172.30.13.103) 56(84) bytes of data.  
64 bytes from 172.30.13.103: icmp_seq=1 ttl=128 time=2.36 ms  
64 bytes from 172.30.13.103: icmp_seq=2 ttl=128 time=1.22 ms  
64 bytes from 172.30.13.103: icmp_seq=3 ttl=128 time=1.72 ms  
64 bytes from 172.30.13.103: icmp_seq=4 ttl=128 time=1.31 ms  
  
--- 172.30.13.103 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3006ms  
rtt min/avg/max/mdev = 1.221/1.651/2.359/0.449 ms  
  
(fahad@fahad)~  
$ |
```

Figure 7 Ping réussi de Kali Linux vers Windows 7

Conclusion de cette étape : la communication est fonctionnelle dans les deux sens. Le laboratoire est donc prêt pour la phase de reconnaissance.

TP 2 3 Phase de reconnaissance

Reconnaissance passive et active

Type	Principe	Exemples
Passive	Collecter des informations publiques sans solliciter directement la cible.	Moteurs de recherche, forums, réseaux sociaux, HackerOne.
Active	Interagir avec la cible autorisée afin d'obtenir des informations techniques.	Ping, SpiderFoot, analyse DNS et scans autorisés.

La reconnaissance passive est plus discrète mais peut fournir moins d'informations techniques. La reconnaissance active est plus riche, mais elle peut être détectée ou bloquée par un pare-feu. Elle ne doit être réalisée que dans un périmètre autorisé.

Repérage des outils disponibles

Dans le menu Kali, la rubrique 01 Reconnaissance regroupe différents outils d'analyse web, d'information réseau et d'OSINT. SpiderFoot a été retenu pour automatiser la collecte.

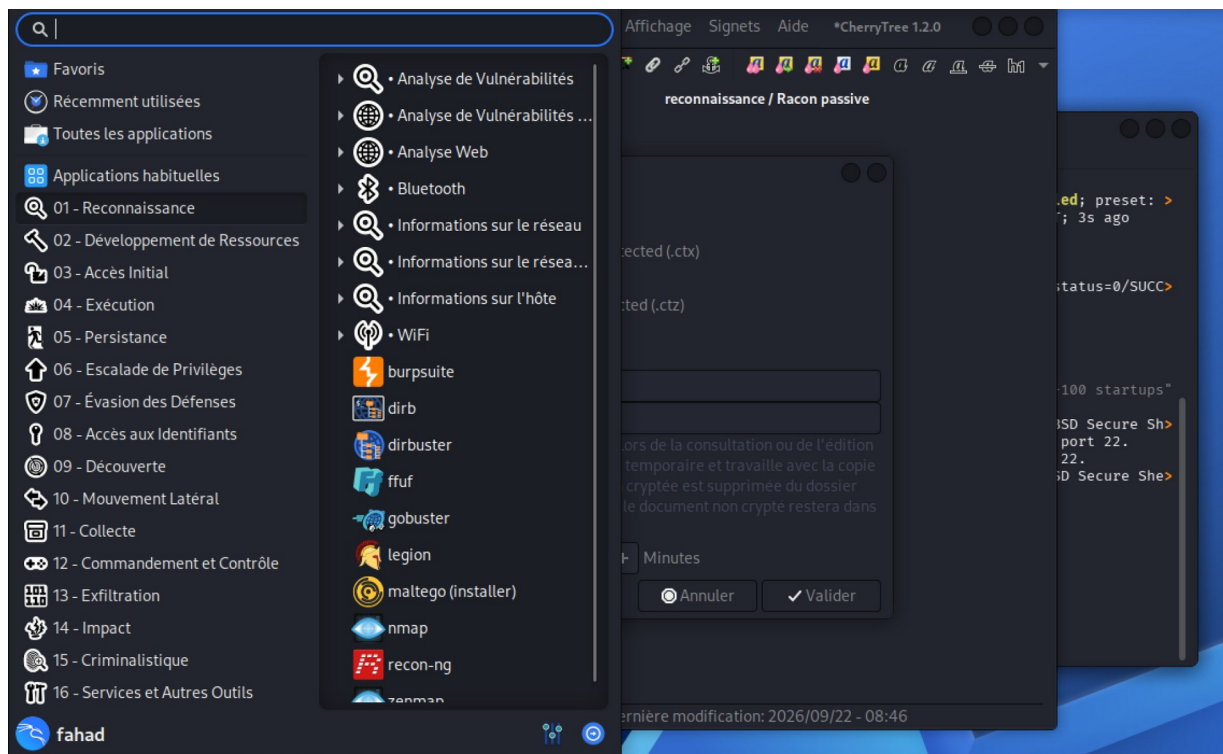


Figure 8 Outils de reconnaissance disponibles dans Kali Linux

Organisation de la documentation dans CherryTree

CherryTree a été utilisé pour classer les notes du test. Deux grandes sections ont été créées : reconnaissance et exploitation. La reconnaissance contient les sous-sections active et passive ; l'exploitation contient MsFvenom, Metasploit et maintien.

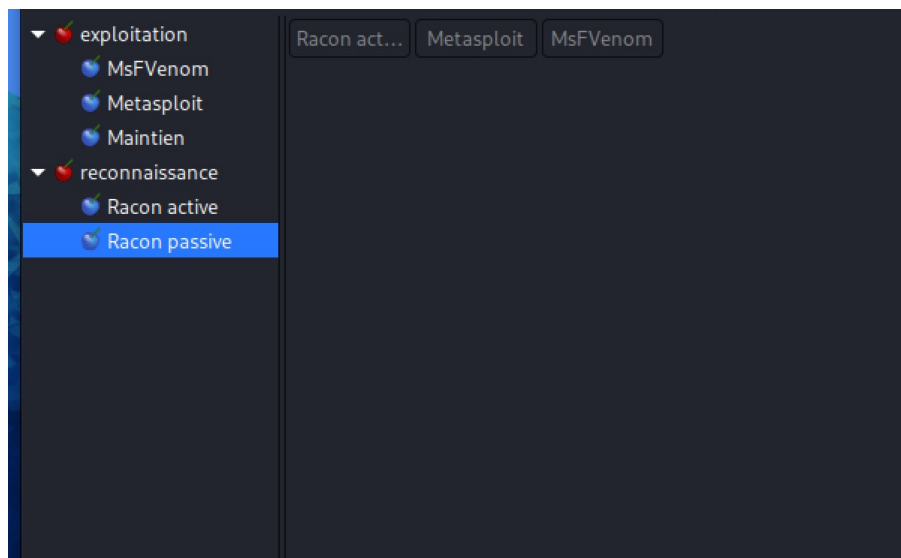


Figure 9 Arborescence finale de documentation dans CherryTree

Une note de reconnaissance active mentionne l'utilisation de SpiderFoot sur le réseau autorisé. La partie passive conserve la trace de la recherche effectuée sur HackerOne. Le document a été enregistré au format CherryTree afin de conserver l'arborescence.

Mise en service de SpiderFoot

SpiderFoot a été lancé comme service web sur l'adresse de la machine Kali. Le navigateur de Kali permet ensuite d'accéder à son interface.

```
spiderfoot -l 172.30.13.102:80
```

```

2 warnings.warn(AST_MULTICAST_UP, LOWER_UP> mtd 1500 qdisc fq_codel state U
[ (root@fahad) - [/home/fahad]
# spiderfoot -l 172.30.13.102:80
2026-09-22 08:57:58,558 [INFO] sf : Starting web server at 172.30.13.102:80
.. valid lft forever preferred lft forever
2026-09-22 08:57:58,590 [WARNING] sf: scope link noprefixroute
*****
Warning: passwd file contains no passwords. Authentication disabled.
Please consider adding authentication to protect this instance!
Refer to https://www.spiderfoot.net/documentation/#security.
*****
[ fahad@fahad ~ ]
[ ~ ]
*****
Use SpiderFoot by starting your web browser of choice and
browse to http://172.30.13.102:80/
*****

```

Figure 10 Démarrage du serveur web SpiderFoot

L'interface a été ouverte à l'adresse suivante :

```
http://172.30.13.102
```

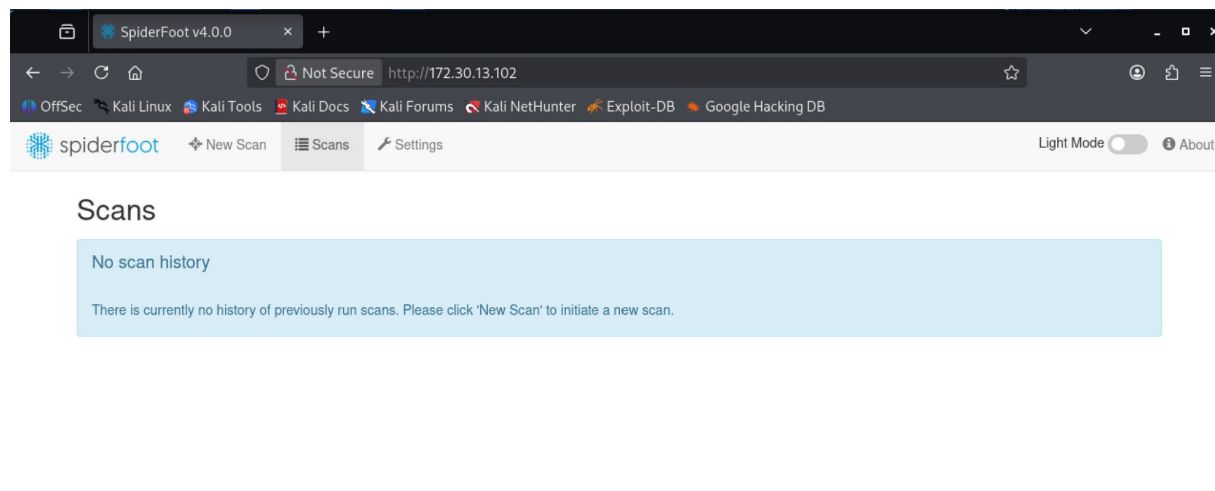


Figure 11 Interface SpiderFoot avant la création du premier scan

Résolution du problème accès Internet

Lors du premier lancement, SpiderFoot n'arrivait pas à télécharger un fichier de configuration depuis Internet. Le journal indiquait Network is unreachable. Le proxy du lycée a donc été déclaré dans les variables d'environnement.

```
export http_proxy="http://172.16.63.130:3128"
export https_proxy="http://172.16.63.130:3128"
export HTTP_PROXY="$http_proxy"
export HTTPS_PROXY="$https_proxy"
source /etc/profile
```

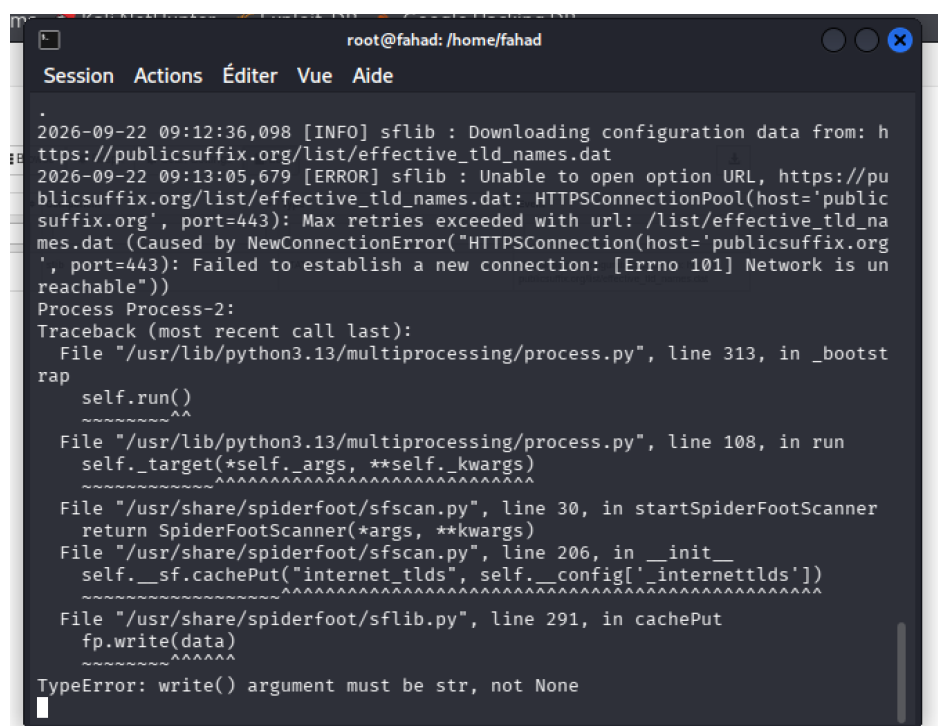


Figure 12 Erreur de connexion observée avant la configuration du proxy

Après cette correction, le scan a démarré. Des erreurs de modules sont toutefois restées présentes lorsque certains services exigeaient une clé API ou un outil externe non configuré.

Exercice 7 Scan du serveur web autorisé

Périmètre et précautions

L'exercice demande de scanner un serveur web local ou appartenant à l'utilisateur et de noter les informations collectées. Le domaine btssiogap.com appartient au serveur pédagogique de la classe et l'enseignant a explicitement autorisé son analyse. Le scan a été limité à la reconnaissance avec SpiderFoot. Aucun test d'exploitation, de mot de passe ou d'accès à la base de données n'a été entrepris.

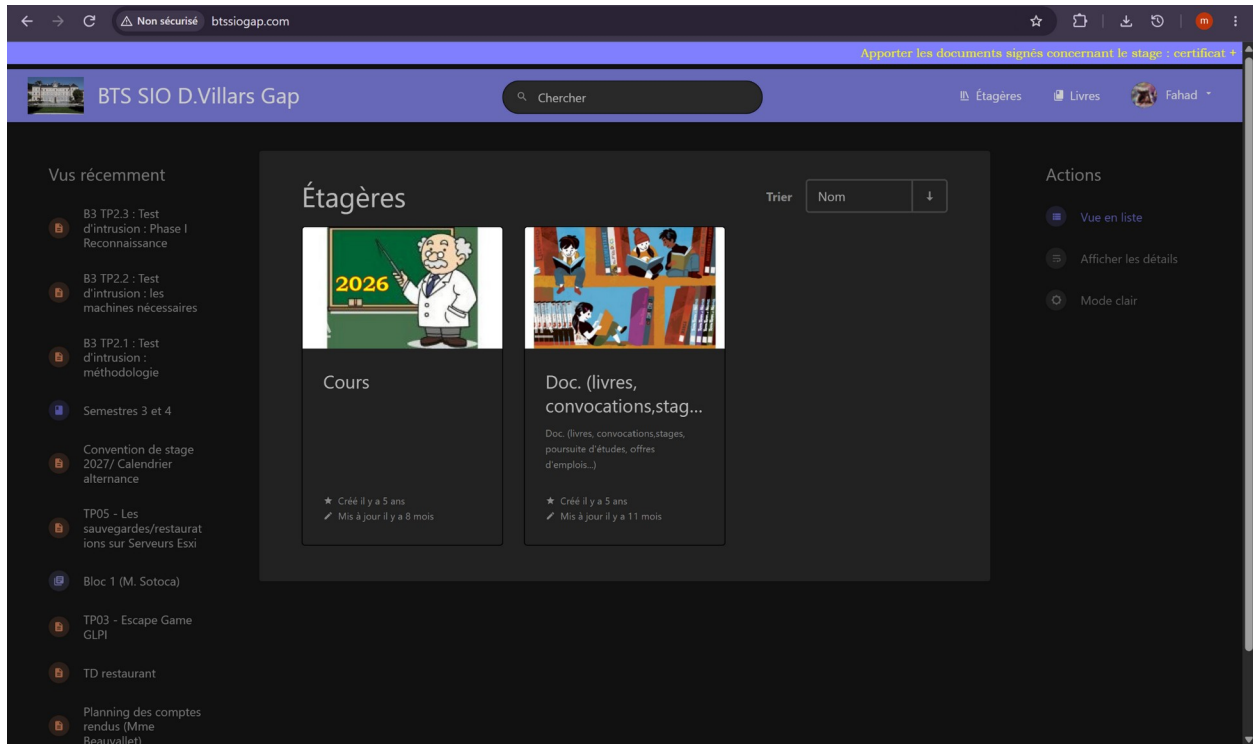


Figure 13 Serveur web pédagogique BTS SIO utilisé comme cible autorisée

Création du scan

Dans SpiderFoot, un nouveau scan a été créé avec le domaine btssiogap.com comme cible. Le mode Footprint est adapté à une collecte d'informations publiques sur le domaine. Le scan a ensuite été lancé depuis le bouton Run Scan Now.

- Ouvrir New Scan dans SpiderFoot.
- Saisir un nom permettant d'identifier clairement le test.
- Saisir btssiogap.com dans le champ Scan Target.
- Choisir le cas d'usage Footprint.
- Lancer le scan et consulter Summary, Browse, Graph et Log.

Not Secure http://172.30.13.102/newscan

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

spiderfoot New Scan Scans Settings Light Mode

New Scan

Scan Name

The name of this scan.

Scan Target

The target of your scan.

ⓘ Your scan target may be one of the following. SpiderFoot will automatically detect the target type based on the format of your input:

Domain Name: e.g. <code>example.com</code>	E-mail address: e.g. <code>bob@example.com</code>
IPv4 Address: e.g. <code>1.2.3.4</code>	Phone Number: e.g. <code>+12345678901</code> (E.164 format)
IPv6 Address: e.g. <code>2606:4700:4700::1111</code>	Human Name: e.g. <code>"John Smith"</code> (must be in quotes)
Hostname/Sub-domain: e.g. <code>abc.example.com</code>	Username: e.g. <code>"jsmith2000"</code> (must be in quotes)
Subnet: e.g. <code>1.2.3.0/24</code>	Network ASN: e.g. <code>1234</code>
Bitcoin Address: e.g. <code>1HesYJSP1QqcyPEjnQ9vzBL1wujruNGe7R</code>	

By Use Case By Required Data By Module

☒ **All** **Get anything and everything about the target.**

All SpiderFoot modules will be enabled (slow) but every possible piece of information about the target will be obtained and analysed.

☐ **Footprint** **Understand what information this target exposes to the Internet.**

Gain an understanding about the target's network perimeter, associated identities and other information that is obtained through a lot of web crawling and search engine use.

⚡ Create a (free) SpiderFoot HX account in seconds and try it out for yourself.

Figure 14 Écran de création d'un nouveau scan SpiderFoot

Informations récoltées

Au moment de la capture finale, le scan était encore en cours. SpiderFoot affichait 26 éléments collectés, dont 25 uniques. Les catégories visibles montrent que la collecte DNS et réseau a fonctionné. Les résultats ci-dessous sont donc un état provisoire et non un résultat définitif.

Information visible	Interprétation
26 éléments au total	Nombre d'événements collectés au moment de la capture.
25 éléments uniques	Presque tous les éléments collectés étaient distincts.
Noms Internet affiliés	Noms ou hôtes associés au domaine analysé.
Enregistrements DNS SPF et TXT	Informations publiées dans la zone DNS du domaine.
Nom de domaine et domaine parent	Identification de la cible et de sa hiérarchie DNS.
Passerelles de messagerie MX	Serveurs déclarés pour la réception des courriels.
Adresses IP et noms associés	Correspondances entre noms DNS et adresses réseau.
Serveurs de noms NS	Serveurs DNS faisant autorité pour le domaine.
Enregistrements DNS bruts	Données DNS collectées directement par les modules.

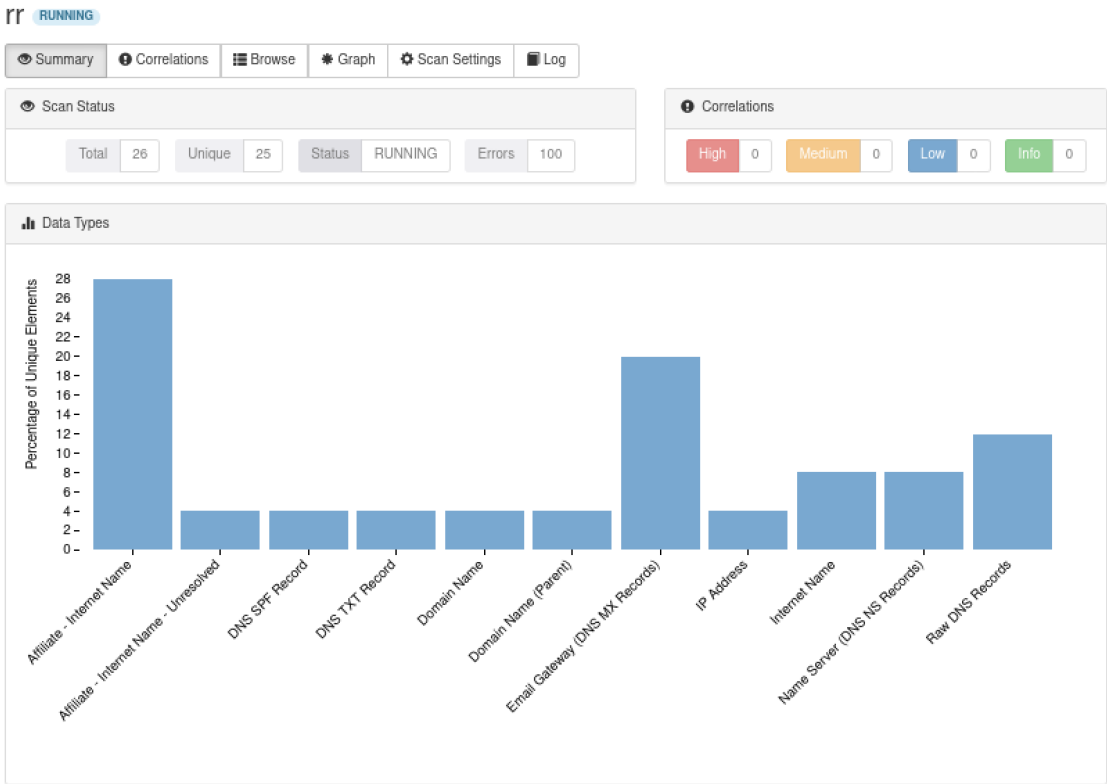


Figure 15 Résultats provisoires du scan SpiderFoot de btssiogap.com

Analyse des erreurs

Le compteur indiquait 100 erreurs au moment de la capture. Cela ne signifie pas que le serveur présente 100 vulnérabilités. Dans SpiderFoot, de nombreux modules dépendent de clés API, d'outils additionnels ou de services externes. Une erreur de module indique donc principalement qu'une source n'a pas pu être interrogée. Les corrélations High, Medium, Low et Info étaient toutes à zéro ; aucune vulnérabilité ne peut être affirmée à partir de cette capture.

Bilan des travaux réalisés

Travail	Résultat
Installation de Kali et VirtualBox	Machine Kali opérationnelle dans VirtualBox.
Additions invité	Intégration et confort d'utilisation améliorés.
Préparation de Windows 7	Machine cible locale installée et adressée.
Configuration réseau	Kali 172.30.13.102 et Windows 7 172.30.13.103 sur le même /16.
Test Windows vers Kali	Réussi, 4 réponses et 0 % de perte.
Test Kali vers Windows	Réussi après adaptation du pare-feu, 4 réponses et 0 % de perte.
Documentation CherryTree	Arborescence active, passive et exploitation enregistrée.
SpiderFoot	Interface démarrée et accès Internet rétabli grâce au proxy.
Exercice 7	Scan de reconnaissance autorisé de btssiogap.com lancé et documenté.

Difficultés rencontrées et solutions

Difficulté	Cause	Solution
Ping impossible dans un sens	Pare-feu Windows bloquant les requêtes ICMP.	Désactivation autorisée du pare-feu par l'enseignant.
SpiderFoot bloqué sur Created	Absence d'accès direct à Internet.	Configuration du proxy 172.16.63.130:3128.
Nombreuses erreurs de modules	Clés API ou outils externes non configurés.	Interprétation prudente et utilisation des données effectivement collectées.
Scan du réseau très long	Le réseau 172.30.0.0/16 contient un grand nombre d'adresses.	Arrêt du test large et choix d'une cible web autorisée plus précise.

Conclusion

Ces travaux pratiques ont permis de construire un laboratoire de test d'intrusion fonctionnel, de vérifier la communication entre Kali Linux et Windows 7 et d'appliquer la première phase d'une méthodologie de

pentest. La distinction entre reconnaissance passive et active a été mise en pratique et les actions ont été documentées dans CherryTree.

L'exercice 7 a été réalisé sur le serveur pédagogique btssiogap.com avec l'autorisation de l'enseignant. SpiderFoot a collecté principalement des informations DNS et réseau. La présence d'erreurs de modules a été analysée sans les confondre avec des vulnérabilités. Aucun accès non autorisé ni aucune exploitation n'a été effectué. Le travail respecte ainsi le périmètre prévu et fournit des preuves exploitables pour la suite du cours.